Contents

Volume 04 — Hash, PKI & Network Attacks (L31–L40) **1**
L31: Cryptographic Hash Functions — Part I 1
L32: Cryptographic Hash Functions — Part II 2
L33: Digital Signature and Certificate 2
L34: Applications — Part I 3
L35: Applications — Part II 3
L36: Steganography 4
L37: Biometrics 5
L38: Network Based Attacks — Part I 5
L39: Network Based Attacks — Part II 6
L40: DNS and Email Security 6

Volume 04 — Hash, PKI & Network Attacks (L31–L40)

> Ethical Hacking · NPTEL 106105217 · Prof. Indranil Sengupta
> **notes-3** — concept exam notes (what things are / what they do). No lab command dumps.

Hash functions, signatures, steganography, biometrics, DNS/email security.

L31: Cryptographic Hash Functions — Part I

What it is / what it does

- **Hash function:** maps arbitrary-length input to fixed-length digest; one-way, deterministic.
- **Properties:** preimage resistance, second-preimage resistance, collision resistance.
- **MD5:** 128-bit output; **broken** for collision attacks (do not use for security).
- **SHA-1:** 160-bit output; deprecated (SHAttered collision demonstrated 2017).
- **SHA-2 family:** SHA-256, SHA-384, SHA-512; current standard (NIST FIPS 180-4).

Defenses (one-liners)

- Use SHA-256 or SHA-3 for integrity verification
- **Salt** passwords before hashing (unique per user)
- Use HMAC or bcrypt/scrypt/Argon2 for password storage
- Deprecate MD5 and SHA-1 in all security contexts

Exam lines

- Hash function properties: **one-way, deterministic, collision-resistant**.
- MD5 output = **128 bits** (32 hex chars); cryptographically broken.
- SHA-256 output = **256 bits** (64 hex chars); current standard.
- Salting prevents **rainbow table** attacks on password hashes.

- Preimage resistance: given hash, cannot find original input.

L32: Cryptographic Hash Functions — Part II

What it is / what it does

- **SHA-3 (Keccak):** sponge construction; different internal design from SHA-2 (safety net).
- **HMAC:** Hash-based MAC = H(K ⊕ opad, H(K ⊕ ipad, message)); provides integrity + authentication.
- **Password hashing:** bcrypt, scrypt, Argon2 — deliberately slow + salted (resist brute-force).
- **Merkle-Damgård construction:** iterative hashing used by MD5, SHA-1, SHA-2.
- **Birthday attack:** find collision in ~2^(n/2) operations for n-bit hash.

Defenses (one-liners)

- Argon2id for password storage (winner of Password Hashing Competition)
- HMAC-SHA256 for message authentication codes
- Full hash output (no truncation below 128 bits)
- Rate limiting on authentication endpoints

Exam lines

- Birthday attack complexity: **2^(n/2)** for n-bit hash.
- HMAC = hash + secret key → provides **authentication + integrity**.
- bcrypt/scrypt/Argon2 are **adaptive** — configurable work factor.
- SHA-3 uses **sponge construction** (not Merkle-Damgård).
- Never store passwords as plain SHA-256 — always use **salt + slow hash**.

L33: Digital Signature and Certificate

What it is / what it does

- **Digital signature:** hash of message encrypted with sender's private key; proves origin + integrity.
- **Verification:** decrypt signature with public key → compare hash of received message.
- **X.509 certificate:** binds public key to identity; signed by Certificate Authority (CA).
- **PKI hierarchy:** Root CA → Intermediate CA → End-entity certificate.
- **Certificate fields:** subject, issuer, validity period, public key, serial number, extensions.

Defenses (one-liners)

- Use trusted public CAs (Let's Encrypt, DigiCert)

- Certificate pinning (HPKP deprecated; use Expect-CT, CAA records)
- OCSP stapling for revocation checking
- Short certificate validity (90 days — Let's Encrypt standard)

Exam lines

- Digital signature uses sender's **private key**; verified with **public key**.
- X.509 certificate binds **identity to public key**, signed by CA.
- PKI chain: Root CA → Intermediate → End-entity.
- Self-signed certs are **not trusted** by default in browsers.
- OCSP checks if certificate has been **revoked** before expiry.

L34: Applications — Part I

What it is / what it does

- **SSL/TLS:** secure transport layer; versions TLS 1.2 and 1.3 current; SSLv3/TLS 1.0/1.1 deprecated.
- **TLS handshake:** ClientHello → ServerHello → Certificate → Key Exchange → Finished.
- **Cipher suite:** key exchange + authentication + bulk encryption + MAC (e.g., TLS_AES_256_GCM_SHA384).
- **Perfect Forward Secrecy (PFS):** ephemeral DH keys — compromise of long-term key doesn't decrypt past sessions.
- **IPsec:** network-layer security; modes: Transport (host-to-host) and Tunnel (gateway-to-gateway).

Defenses (one-liners)

- Enforce TLS 1.2+ only; prefer TLS 1.3
- Disable weak ciphers (RC4, 3DES, NULL, EXPORT)
- Enable HSTS header: Strict-Transport-Security:
- Use ECDHE cipher suites for forward secrecy

Exam lines

- TLS provides **confidentiality + integrity** at transport layer.
- TLS 1.3 reduces handshake to **1-RTT** (faster than TLS 1.2's 2-RTT).
- PFS ensures past sessions safe even if **long-term key compromised**.
- IPsec **Tunnel mode** encrypts entire IP packet (VPN use case).
- Cipher suite specifies: key exchange, authentication, encryption, MAC algorithms.

L35: Applications — Part II

What it is / what it does

- **PGP/GPG:** email encryption and signing; web of trust model (vs PKI hierarchy).

- **S/MIME:** email encryption using X.509 certificates (enterprise standard).
- **VPN protocols:** IPsec (IKEv2), OpenVPN (SSL/TLS), WireGuard (modern, lightweight).
- **SSH:** secure remote shell; key-based auth preferred over passwords.
- **Kerberos:** network authentication using tickets (Active Directory).

Defenses (one-liners)

- SSH key-based auth with Ed25519 keys; disable password auth
- GPG key passphrase protection; hardware token (YubiKey)
- Kerberos AES encryption; monitor for TGS-REQ anomalies
- VPN MFA + certificate-based authentication

Exam lines

- PGP uses **web of trust**; S/MIME uses **PKI/X.509**.
- SSH default port = **22**; key-based auth more secure than passwords.
- Kerberos uses **tickets** (TGT + service tickets) for authentication.
- OpenVPN tunnels traffic over **SSL/TLS** (port 443/UDP 1194).
- WireGuard is a modern VPN using **Curve25519** key exchange.

L36: Steganography

What it is / what it does

- **Steganography:** hiding secret data within innocuous carrier (image, audio, video, text).
- **LSB (Least Significant Bit):** replace least significant bits of pixel values with secret bits.
- **Steganalysis:** detecting hidden data via statistical analysis (chi-square, RS analysis).
- **Tools hide data in:** image formats (BMP, PNG), audio (WAV), documents (PDF).
- **Difference from encryption:** steganography conceals **existence**; encryption conceals **content**.

Defenses (one-liners)

- Re-encode images (destroys LSB steganography)
- DLP scanning for anomalous file entropy
- Monitor outbound file transfers for unusual patterns
- Hash comparison of known-clean vs suspect media

Exam lines

- LSB steganography modifies **least significant bits** of pixel values.
- Steganography hides message **existence**; cryptography hides **content**.
- steghide supports JPEG and BMP with optional passphrase encryption.
- Chi-square test detects **non-random LSB distribution** (steganalysis).

- binwalk identifies and extracts embedded files by signature scanning.

L37: Biometrics

What it is / what it does

- **Biometric modalities:** fingerprint, iris, face, voice, gait, palm print.
- **Performance metrics:** FAR (False Accept Rate), FRR (False Reject Rate), EER (Equal Error Rate).
- **Liveness detection:** distinguish live person from photo/mold/replay attack.
- **Template storage:** store feature vectors, not raw images; irreversible transforms preferred.
- **Multimodal biometrics:** combine two+ modalities for higher accuracy.

Defenses (one-liners)

- Liveness detection (blink, pulse, challenge-response)
- Cancelable biometrics (revocable templates)
- Multimodal fusion (fingerprint + iris)
- Store templates with homomorphic encryption or secure enclave

Exam lines

- FAR = unauthorized user **accepted**; FRR = authorized user **rejected**.
- EER = point where FAR equals FRR (lower is better).
- Biometric templates **cannot be changed** if compromised (unlike passwords).
- Liveness detection prevents **presentation attacks** (spoofing).
- Multimodal biometrics improves accuracy by combining modalities.

L38: Network Based Attacks — Part I

What it is / what it does

- **Sniffing:** capture packets on network segment (promiscuous mode).
- **Spoofing types:** IP spoofing, MAC spoofing, email spoofing, DNS spoofing.
- **Session hijacking:** take over established TCP session using stolen seq/ack numbers.
- **TCP RST attack:** send forged RST to tear down connection.
- **DNS cache poisoning:** inject false DNS records into resolver cache.

Defenses (one-liners)

- Switches (not hubs) + port security
- Encrypt traffic (TLS everywhere)
- DNSSEC prevents cache poisoning
- Randomized TCP ISN (initial sequence numbers)

Exam lines

- Promiscuous mode captures **all frames** on segment (not just addressed to host).
- DNS cache poisoning injects **false records** into resolver cache.
- TCP session hijacking requires knowing/c predicting **sequence numbers**.
- IP spoofing: forge source IP (used in DDoS reflection attacks).
- Switches limit sniffing to own port traffic (unless ARP spoofed or MAC flooded).

L39: Network Based Attacks — Part II

What it is / what it does

- **Firewall types:** packet-filtering (stateless), stateful inspection, application-layer (proxy).
- **IDS (Intrusion Detection):** passive monitoring, alerts on suspicious patterns (Snort, Suricata).
- **IPS (Intrusion Prevention):** active blocking of detected threats.
- **Detection methods:** signature-based (known patterns) vs anomaly-based (baseline deviation).
- **Evasion techniques:** fragmentation, encoding, timing attacks, encrypted payloads.

Defenses (one-liners)

- Stateful firewall with default-deny policy
- IDS/IPS with updated signature sets
- Deep packet inspection and reassembly
- Network segmentation and zero-trust architecture

Exam lines

- Stateful firewall tracks **connection state** (unlike stateless packet filter).
- IDS = **detect and alert**; IPS = **detect and block**.
- Signature-based IDS matches **known attack patterns** (Snort rules).
- Anomaly-based IDS detects **deviations from baseline** behavior.
- Fragmentation evades IDS that doesn't **reassemble packets** before inspection.

L40: DNS and Email Security

What it is / what it does

- **DNS record types:** A, AAAA, MX, NS, TXT, CNAME, PTR, SOA.
- **DNSSEC:** cryptographically signs DNS records (RRSIG, DNSKEY, DS); prevents spoofing.
- **Email security protocols:** SPF (authorized senders), DKIM (signed messages), DMARC (policy enforcement).
- **SPF:** TXT record listing permitted sending IPs for domain.

- **DKIM:** digital signature in email header; verified against public key in DNS TXT.
- **DMARC:** policy telling receivers what to do with SPF/DKIM failures (none/quarantine/reject).

Defenses (one-liners)

- Implement SPF + DKIM + DMARC (p=reject)
- Enable DNSSEC on all zones
- Monitor DMARC aggregate reports
- Lock domain registrar account with MFA

Exam lines

- SPF = **authorized sending IP addresses** for a domain.
- DKIM = **cryptographic signature** on email headers/body.
- DMARC = **policy** for handling SPF/DKIM failures.
- DNSSEC prevents **DNS response spoofing** via digital signatures.
- MX record specifies **mail server** for domain.